

Project Contribution Template

Source template: [resources/2022-2023-HK2-GroupXX-Project Contribution.xlsx](#)

Summary

Field	Value
Topic	T09 - Security Testing (DAST / SAST)
Group	Nhóm 06 - KDBK
Members	23127075 - Lê Trung Kiên 23127185 - Mai Thị Kim Duyên 23127205 - Lâm Hữu Khánh 23127326 - Lê Mai Hoài Bảo

Project Metrics

Metric	Value	Note
Number of students working in the project	4	Input
Number of tasks	45	Calculated from student task counts
Number of task hours	137.5	Calculated from student task hours
Number of Git commits	144	Calculated from student Git commits
Max student percentage	25%	Calculated from Percent column
Project score	Entered by TA or estimated by students	

Instructions

Do not edit the grey cells. TAs will enter the score of all PAs in the project score and get the individual scores. Students can enter an estimated project score to see how percentages affects your scores.

Use columns Tasks - Percent, Task Hours - Percent, Git - Percent as references for column Percent.

Student Contribution Summary

No	Student ID	Full name	Tasks	Tasks - Percent	Task Hours	Task Hours - Percent	Git Commits	Git - Percent	Percent	Score - Student	Score - TA
1	23127075	Lê Trung Kiên	12	27%	35	25%	54	38%	25%	10	
2	23127185	Mai Thị Kim Duyên	10	22%	32.5	24%	21	15%	25%	10	

No	Student ID	Full name	Tasks	Tasks - Percent	Task Hours	Task Hours - Percent	Git Commits	Git - Percent	Percent	Score - Student	Score - TA
3	23127205	Lâm Hữu Khánh	10	22%	35	25%	28	19%	25%	10	
4	23127326	Lê Mai Hoài Bảo	13	29%	35	25%	41	28%	25%	10	

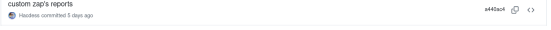
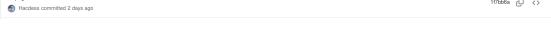
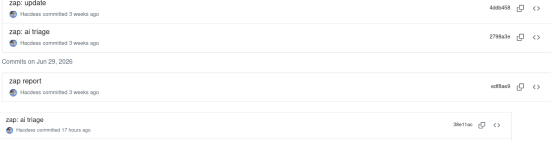
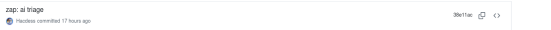
Original Formula Reference

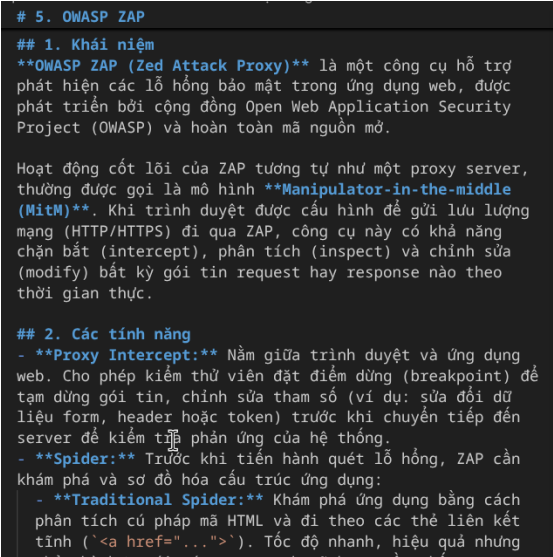
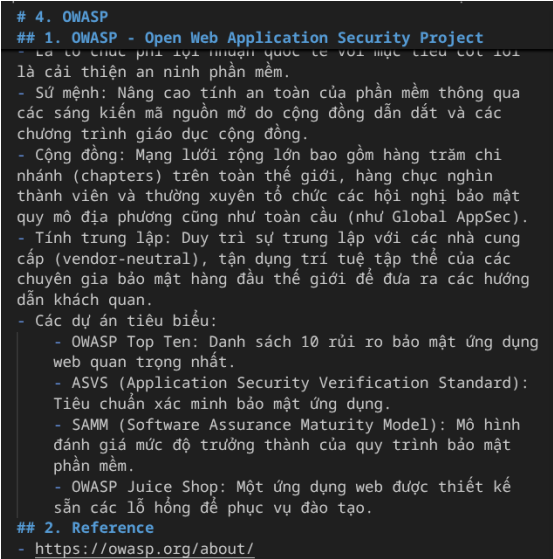
Cell / Column	Formula or rule
D7	<code>SUM(D17:D25)</code>
D8	<code>SUM(F17:F25)</code>
D9	<code>SUM(H17:H25)</code>
D10	<code>MAX(J17:J25)</code>
Tasks - Percent	<code>IF(\$D\$7=0, 0, Tasks / \$D\$7)</code>
Task Hours - Percent	<code>IF(\$D\$8=0, 0, Task Hours / \$D\$8)</code>
Git - Percent	<code>IF(\$D\$9=0, 0, Git Commits / \$D\$9)</code>
Score - Student	<code>IF(Percent=\$D\$10, \$D\$11, ROUND(2 * (\$D\$11 - \$D\$11 * (1 - Percent / \$D\$10)), 0) / 2)</code>

Tasks

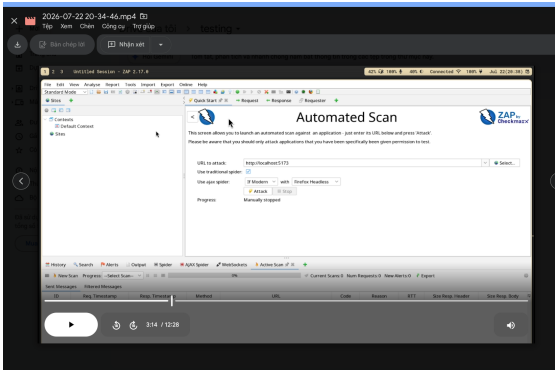
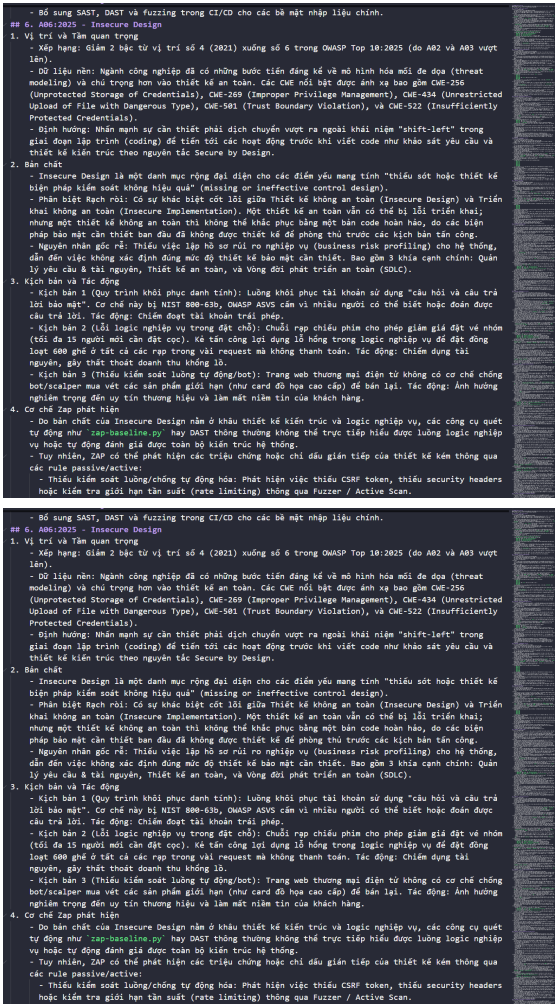
A task should be done by only 1-2 students. Duplicate tasks are not recommended. Each member should work on at least 5 tasks.

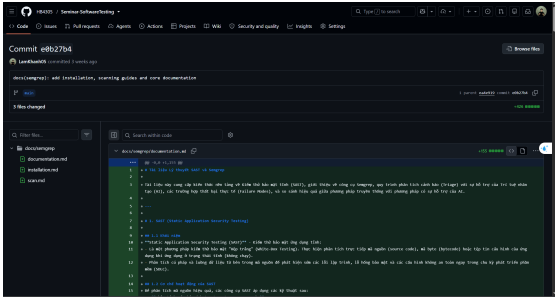
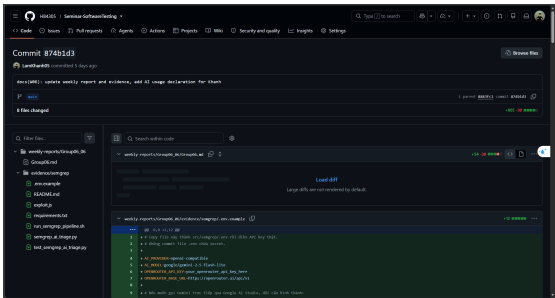
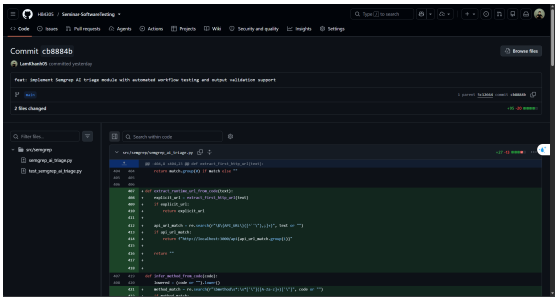
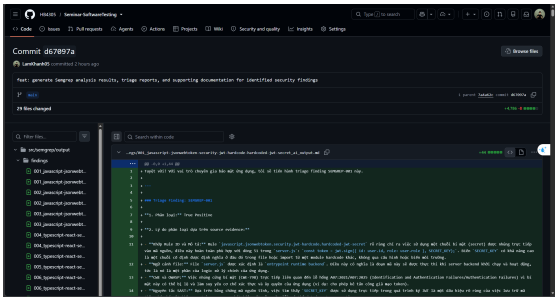
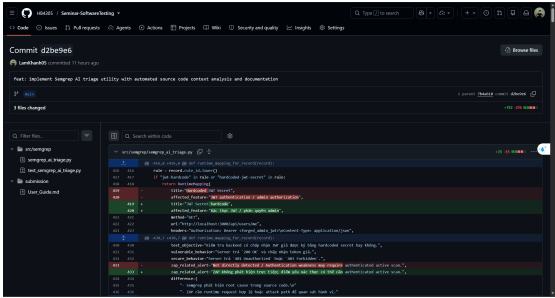
No	Student ID	Full name	Task Description	Hours	Evidence
1	23127075	Lê Trung Kiên	Tìm hiểu về DAST và ghi vào user guide.	0.5	

No	Student ID	Full name	Task Description	Hours	Evidence
2	23127075	Lê Trung Kiên	Tìm hiểu về ZAP và ghi vào user guide.	3	<pre>## 3. OWASP ZAP ### 3.1. Khái niệm **OWASP ZAP (Zed Attack Proxy)** là một công cụ hỗ trợ phát hiện các lỗ hổng bảo mật trong ứng dụng web, được phát triển bởi cộng đồng Open Web Application Security Project (OWASP) và hoàn toàn mã nguồn mở. Hoạt động cốt lõi của ZAP tương tự như một proxy server, thường được gọi là mô hình "Manipulator-in-the-middle (MitM)". Khi trình duyệt được cấu hình để gửi lưu lượng mạng (HTTP/HTTPS) đi qua ZAP, công cụ này có khả năng chặn bắt (intercept), phân tích (inspect) và chỉnh sửa (modify) bất kỳ gói tin request hay response nào theo thời gian thực. ### 3.2. Các tính năng - **Proxy Intercept:** Nằm giữa trình duyệt và ứng dụng web. Cho phép kiểm thử viên đặt điểm dừng (breakpoint) để tạm dừng gói tin, chỉnh sửa tham số (ví dụ: sửa đổi dữ liệu form, header hoặc token) trước khi chuyển tiếp đến server để kiểm tra phản ứng của hệ thống. - **Spider:** Trước khi tiến hành quét lỗ hổng, ZAP cần khám phá và sơ đồ hóa cấu trúc ứng dụng: - **Traditional Spider:** Khám phá ứng dụng bằng cách phân tích cú pháp mã HTML và đi theo các thẻ liên kết tĩnh (). Tác động nhanh, hiệu quả nhưng chỉ phù hợp với các trang web tĩnh truyền thống. - **AJAX Spider:** Khởi chạy một trình duyệt thực tế ngấm để tương tác (click, cuộn trang, điền form), từ đó phát hiện các endpoint động được tạo ra bởi JavaScript/AJAX. - **Passive Scan:** Quét bị động, hoàn toàn không can thiệp vào traffic (không chỉnh sửa gói tin và không gửi các request tấn công tới server). Mục đích chính là tìm ra các lỗ hổng cấu hình hoặc rò rỉ thông tin (ví dụ: thiếu HTTP Security Headers, lộ thông tin nhạy cảm qua response header). - **Active Scan:** Thiết chủ động, tự tạo và gửi các request chứa payload độc hại đến server để dò tìm các lỗ hổng như SQL Injection, XSS, CSRF... - **Baseline Scan:** Là kịch bản kiểm thử tự động hóa động gói scan (automation script), thường được thực thi thông qua Docker hoặc tài script này kết hợp với Spider nhấm và Passive Scan để đánh giá nhanh bảo mật. - **Fuzzing:** Kỹ thuật thay thế một hoặc nhiều tham số trong gói tin request bằng danh sách lớn các dữ liệu thử nghiệm (ví dụ: thay thế tham số email bằng danh sách 1 triệu email hoặc chuỗi ký tự đặc biệt để kiểm tra tính ổn định/lỗi của hệ thống). - **Report:** Tự động tạo báo cáo chi tiết về các lỗ hổng bảo mật được tìm thấy. Hỗ trợ xuất ra nhiều định dạng khác nhau như: HTML, XML, JSON, PDF... **Note:** Có 2 cách chính để sử dụng ZAP: thông qua giao diện người dùng (Desktop App) hoặc thông qua API/</pre>
3	23127075	Lê Trung Kiên	Tìm hiểu về OWASP Top 10: 1, 2 và ghi vào user guide.	1	<pre>## 4. OWASP Top 10 rule-set OWASP Top 10 là một tài liệu nâng cao nhận thức tiêu chuẩn dành cho các nhà phát triển và chuyên gia bảo mật ứng dụng web, liệt kê 10 rủi ro bảo mật quan trọng nhất. ### 4.1. A01:2025 - Broken Access Control 1. Vị trí và Tầm quan trọng - Xếp hạng: Giữ vị trí số 1 trong OWASP Top 10:2025. - Dữ liệu nền: 100% ứng dụng được kiểm thử có ít nhất một biểu hiện liên quan; nhóm này có 40 CVE được ảnh hưởng, tỷ lệ xuất hiện trung bình 3,78% và số lần xuất hiện rất cao. - Điểm đáng chú ý: OWASP đưa ra các SSRF vào phạm vi của Broken Access Control trong bản 2025. 2. Bản chất - Lỗi xảy ra khi backend không tuân thủ đúng chính sách phân quyền, khiến user hoặc client có thể đọc, sửa, xóa hoặc gọi chức năng vượt quá quyền được cấp. - Các dạng phổ biến gồm IDOR, force browsing, leo thang đặc quyền, bỏ sót kiểm tra quyền ở API 'POST/PUT/DELETE', giả mạo hoặc tái sử dụng JWT/cookie, và CORS mở sai đối tượng. 3. Kích bản và Tác động - Kê tấn công đối tượng số 'acct', 'userid' hoặc đường dẫn tài nguyên để xem dữ liệu của người khác. Tác động là rò rỉ dữ liệu trái phép và phá vỡ tính riêng tư. - User thường hoặc user chưa đăng nhập truy cập được URL quản trị nhờ đoán endpoint hoặc gọi API trực tiếp thay vì đi qua UI. Tác động là leo thang đặc quyền và thao tác nghiệp vụ trái phép. - Token/cookie bị replay sau logout hoặc bị sửa metadata để tăng quyền. Tác động là chiếm phiên, thay đổi dữ liệu hoặc thực hiện hành động nhạy cảm. 4. Cơ chế ZAP phát hiện - ZAP-baseline.py chỉ spider và passive scan nên không đủ để kết luận Broken Access Control; nó chủ yếu phát hiện chỉ dấu gián tiếp như thiếu CSRF token, CORS quá rộng, session ID trên URL. - ZAP Access Control Testing add-on cho phép khai báo 'Context', 'User', 'Access Rules', sau đó thử truy cập từng URL dưới góc nhìn từng user để tìm lỗi Improper Authentication 'A01:2018' và Improper Authorization 'A01:2012'. - Forced Browse giúp lộ các URL/đường dẫn bị quên bảo vệ; authenticated spider giúp thu thập thêm các route chỉ hiển sau đăng nhập. 5. Cấu hình baseline - Dùng baseline có context và user để crawl ứng dụng cần kiểm thử: - zap-baseline.py -t 'target' -n <context_file> -U <user> -j - Nên giữ hoặc nâng mức cảnh báo cho các rule gọi ý lỗi truy cập: - '100202 WARN' hoặc 'FAIL' cho 'CSRF Countermeasures' - '100206 WARN' cho 'Cross Domain Misconfiguration' - '13 FAIL' cho 'Session ID in URL Rewrite'</pre>
4	23127075	Lê Trung Kiên	Cài đặt và chạy cơ bản ZAP và ghi vào user guide.	5	
5	23127075	Lê Trung Kiên	Cấu hình output format của ZAP scan.	5	
6	23127075	Lê Trung Kiên	Tạo Activity Worksheet	1	
7	23127075	Lê Trung Kiên	Cấu hình authenticated ZAP scan với ZAP GUI.	5	
8	23127075	Lê Trung Kiên	Viết script tạo AI Triage cho ZAP scan.	5	
9	23127075	Lê Trung Kiên	Viết script tạo testcase cho ZAP scan.	5	
10	23127075	Lê Trung Kiên	Viết outline thuyết trình và slide.	1	

No	Student ID	Full name	Task Description	Hours	Evidence
11	23127075	Lê Trung Kiên	Khởi tạo slide thuyết trình cho nhóm (sườn và nội dung được giao).	3	
12	23127075	Lê Trung Kiên	Tạo final-report.	0.5	
13	23127185	Mai Thị Kim Duyên	Tìm hiểu về ZAP.	3	
14	23127185	Mai Thị Kim Duyên	Tìm hiểu về OWASP.	1	

5 / 10

No	Student ID	Full name	Task Description	Hours	Evidence
22	23127185	Mai Thị Kim Duyên	Phối hợp quay video demo workflow.	10	
23	23127205	Lâm Hữu Khánh	Tìm hiểu về SAST.	1	
24	23127205	Lâm Hữu Khánh	Tìm hiểu về Semgrep.	1	
25	23127205	Lâm Hữu Khánh	Tìm hiểu về OWASP Top 10: 5; 6.	1	

No	Student ID	Full name	Task Description	Hours	Evidence
26	23127205	Lâm Hữu Khánh	Track Semgrep: Cài đặt và chạy Semgrep.	5	
27	23127205	Lâm Hữu Khánh	Track Semgrep: Tạo flow Test với Semgrep, AI Triage (có báo cáo output).	5	
28	23127205	Lâm Hữu Khánh	Cài đặt và chạy cơ bản Track Zap theo hướng dẫn đã viết.	5	
29	23127205	Lâm Hữu Khánh	Hoàn thiện Track Semgrep trên EShop, bổ sung evidence, output scan, AI triage và ghi chú kiểm chứng.	8	
30	23127205	Lâm Hữu Khánh	Rà soát bộ evidence Track ZAP, đối chiếu các tùy chọn CLI và bổ sung hướng dẫn chạy lại basic scan từ root project.	3	
31	23127205	Lâm Hữu Khánh	Viết slide và user guide hướng dẫn chạy basic scan và cách chạy Semgrep trong pipeline.	3	

8 / 10

9 / 10

10 / 10